

Manual: Computação em Nuvem (AWS, Azure e Google Cloud)

Modelos e Multicloud, Redes (VPC, NSG), VPN, Direct Connect e ExpressRoute, Computação e Serverless, Dados em Nuvem, IAM, RBAC e MFA, KMS, Zero Trust, IaC, FinOps, Alta Disponibilidade e Migração

CHANCELA EDITORIAL YLUNA85 LABS

Preparação Conjunta: Auditor Fiscal (TI) & Agente de Tributos Estaduais

Revisão Ortográfica e Glossário Geral de Siglas

Material de livre circulação interna. Revisado em Português Brasileiro (pt-BR).

1. Fundamentos, Modelos de Adoção e Pilares de Arquitetura

A computação em nuvem entrega recursos de TI sob demanda pela rede, com pagamento pelo uso. Esta apostila parte das definições do NIST SP 800-145 (veja a apostila de Infraestrutura) e trata das plataformas AWS, Azure e Google Cloud.

- **Revisão rápida do NIST SP 800-145**

Cinco características: autosserviço sob demanda, amplo acesso à rede, pool de recursos, rápida elasticidade e serviço medido. Modelos de serviço: IaaS, PaaS e SaaS. Modelos de implantação: pública, privada, comunitária e híbrida.

- **Regiões e zonas de disponibilidade**

Região é uma área geográfica com centros de dados. Zona de disponibilidade (AZ) é um ou mais centros de dados isolados, com energia, rede e refrigeração próprias, dentro da região. As regiões geralmente têm três ou mais zonas. Implantar em várias zonas protege contra falha de um centro de dados; em várias regiões, contra falha regional.

- **Responsabilidade compartilhada**

O provedor cuida da segurança da nuvem (instalações, hardware e a plataforma). O cliente cuida da segurança na nuvem: identidades, dados, configuração e, em IaaS, sistema operacional e aplicações. A parte do cliente cresce de SaaS para PaaS e IaaS.

- **Estratégias de migração (os "Rs")**

Rehost (lift-and-shift, mover como está), Replatform (pequenos ajustes, como usar banco gerenciado), Refactor ou Re-architect (reprojetar para a nuvem), Repurchase (trocar por SaaS), Retire (desativar) e Retain (manter onde está). O modelo da AWS acrescenta Relocate (mover sem alterar, por exemplo VMware).

- **Pilares de arquitetura bem estruturada**

AWS Well-Architected: excelência operacional, segurança, confiabilidade, eficiência de desempenho, otimização de custos e sustentabilidade (seis pilares). Azure Well-Architected: confiabilidade, segurança, otimização de custos, excelência operacional e eficiência de desempenho (cinco pilares).

PROVEDOR PROTEGE A NUVEM, CLIENTE PROTEGE O QUE COLOCA NELA

Contratar nuvem não transfere a responsabilidade pelos dados, pelas identidades e pelas configurações. Bucket público por engano é responsabilidade do cliente.

2. Nuvem Híbrida, Multicloud, Portabilidade e Soberania de Dados

Organizações raramente usam um único ambiente. Combinam centro de dados próprio, nuvens de vários provedores e, às vezes, borda.

- **Híbrida versus multicloud**

Híbrida: integra ambiente local (on-premises) e nuvem pública. Multicloud: usa serviços de mais de um provedor de nuvem pública. Podem coexistir. Motivos: resiliência, negociação, serviços específicos e requisitos regulatórios.

- **Vantagens e custos do multicloud**

Reduz a dependência de um provedor e permite escolher o melhor serviço para cada caso. Em contrapartida, aumenta a complexidade operacional, exige competências diversas, dificulta o uso de serviços gerenciados exclusivos e pode elevar custos de transferência de dados.

- **Lock-in e portabilidade**

Lock-in é a dependência de recursos proprietários de um provedor. Mitigações: contêineres e Kubernetes, infraestrutura como código independente de provedor (por exemplo, Terraform), padrões abertos e camadas de abstração. Portabilidade total é rara e tem custo.

- **Residência e transferência internacional de dados**

A LGPD trata da transferência internacional de dados pessoais nos arts. 33 a 36, permitindo-a em hipóteses como países com nível adequado de proteção e cláusulas contratuais específicas, conforme regulamentação da ANPD. Ao escolher a região da nuvem, considere onde os dados ficam armazenados e processados.

- **Computação de borda (edge)**

Processa dados perto da origem para reduzir latência e tráfego. Complementa a nuvem em cenários como IoT.

MULTICLOUD NÃO É AUTOMÁTICO NEM GRATUITO

Usar dois provedores não garante resiliência: é preciso projetar dados, rede e identidade para funcionar entre eles.

3. Redes na Nuvem: VPC, Sub-redes, Gateways e Grupos de Segurança

A rede virtual isola e conecta os recursos na nuvem. Cada provedor tem nomes próprios: VPC na AWS e no Google Cloud, e VNet na Azure.

- **VPC ou VNet e sub-redes**

A rede virtual tem um bloco de endereços (CIDR) dividido em sub-redes. Sub-rede pública tem rota para a Internet por um gateway de Internet. Sub-rede privada não é acessível diretamente da Internet; para saída usa um gateway NAT. Na AWS as sub-redes ficam em uma zona; no Google Cloud, as sub-redes são regionais.

- **Tabelas de rotas e gateways**

A tabela de rotas define para onde vai o tráfego de cada sub-rede. Gateway de Internet permite comunicação com a Internet. Gateway NAT permite que recursos privados iniciem conexões de saída sem receber conexões de entrada.

- **Grupos de segurança e listas de controle**

Na AWS, grupos de segurança são firewalls com estado (stateful) aplicados a instâncias e interfaces, com regras apenas de permissão. As ACLs de rede (NACLs) são sem estado (stateless), aplicadas às sub-redes, com regras de permissão e de negação avaliadas em ordem numérica. Na Azure, o Network Security Group (NSG) tem estado e regras de permissão e negação com prioridade.

- **Interconexão de redes**

Peering liga duas redes virtuais e não é transitivo. Para muitas redes usa-se um hub: AWS Transit Gateway, Azure Virtual WAN ou hub-and-spoke, Google Network Connectivity Center. Endpoints privados (AWS PrivateLink, Azure Private Link, Google Private Service Connect) permitem acessar serviços por endereços privados, sem passar pela Internet.

- **Balanceamento, DNS e CDN**

Balanceadores: AWS ELB (Application Load Balancer na camada 7 e Network Load Balancer na camada 4), Azure Load Balancer (camada 4) e Application Gateway (camada 7), Google Cloud Load Balancing. DNS gerenciado: Route 53, Azure DNS e Cloud DNS. CDN: CloudFront, Azure Front Door ou CDN e Cloud CDN.

SECURITY GROUP TEM ESTADO, NACL NÃO TEM

Grupo de segurança é stateful: a resposta a um tráfego permitido é liberada automaticamente. NACL é stateless: é preciso liberar ida e volta. NACL aceita regras de negação; grupo de segurança, só de permissão.

4. Conectividade com o Ambiente Local: VPN, Direct Connect, ExpressRoute e Interconnect

A conexão entre o centro de dados e a nuvem pode ser feita pela Internet, com VPN, ou por link privado dedicado.

- **VPN site-to-site**

Túneis IPsec criptografados sobre a Internet, de implantação rápida e menor custo, com desempenho sujeito à Internet. AWS Site-to-Site VPN (dois túneis por conexão), Azure VPN Gateway e Google Cloud HA VPN.

- **Links privados dedicados**

AWS Direct Connect, Azure ExpressRoute e Google Cloud Interconnect (Dedicated ou Partner). Ligam a rede do cliente ao provedor sem passar pela Internet pública, com latência mais previsível, maior largura de banda e, em geral, menor custo de saída de dados. Exigem contratação de circuito e provedor de conectividade, com prazo maior de implantação.

- **Detalhes do Direct Connect e do ExpressRoute**

Direct Connect usa interfaces virtuais (VIFs): privada (acesso a VPCs), pública (serviços públicos da AWS) e de trânsito (Transit Gateway). ExpressRoute oferece peering privado (redes virtuais) e peering da Microsoft (serviços Microsoft e Microsoft 365); o ExpressRoute Global Reach liga locais entre si pela rede da Microsoft.

- **Criptografia nos links dedicados**

Link privado não significa link criptografado. Em geral, não é criptografado por padrão. Para proteger o tráfego, combine com VPN IPsec sobre o link ou com MACsec, quando o serviço suportar.

- **Alta disponibilidade**

Use conexões redundantes, em locais distintos, e mantenha uma VPN como reserva do link dedicado. Roteamento dinâmico por BGP entre a rede do cliente e a nuvem.

DEDICADO NÃO É SINÔNIMO DE CIFRADO

Direct Connect, ExpressRoute e Interconnect evitam a Internet pública, mas não cifram o tráfego por padrão. Para sigilo, use VPN IPsec ou MACsec.

5. Computação: Máquinas Virtuais, Autoescalamento e Modelos de Preço

A base da computação é a máquina virtual, e sobre ela vêm o escalonamento automático e os modelos de compra.

- **Máquinas virtuais**

AWS EC2, Azure Virtual Machines e Google Compute Engine. O cliente escolhe família e tamanho (CPU, memória, rede, GPU), imagem e disco, e é responsável pelo sistema operacional e pelas atualizações.

- **Autoescalamento e balanceamento**

Grupos de escalonamento adicionam ou removem instâncias conforme métricas ou agenda: AWS Auto Scaling Groups, Azure Virtual Machine Scale Sets e Google Managed Instance Groups. Combinam-se com balanceadores e verificações de saúde para substituir instâncias com falha. Escalar horizontalmente é acrescentar instâncias; verticalmente, aumentar o tamanho da instância.

- **Modelos de compra**

Sob demanda (sem compromisso); reservas e planos de economia (compromisso de um ou três anos em troca de desconto: AWS Reserved Instances e Savings Plans, Azure Reservations e Savings Plan, Google Committed Use Discounts); e instâncias interrompíveis, muito mais baratas, para cargas tolerantes a interrupção (AWS Spot, Azure Spot, Google Spot VMs).

- **Sem estado e resiliência**

Para escalar e se recuperar, as instâncias devem ser descartáveis: sem estado local relevante, com dados em serviços gerenciados e configuração automatizada.

- **Contêineres gerenciados**

Kubernetes gerenciado: Amazon EKS, Azure AKS e Google GKE. Contêineres sem gerenciar servidores: AWS Fargate, Azure Container Apps e Google Cloud Run. O plano de controle do Kubernetes é operado pelo provedor; o cliente gerencia cargas e nós (ou usa modos sem servidor).

ESCALA HORIZONTAL EXIGE APLICAÇÃO SEM ESTADO

Para adicionar instâncias iguais atrás de um balanceador, cada requisição pode ir a qualquer uma. Sessões e arquivos devem ficar fora da instância (cache, banco, armazenamento de objetos).

6. Serverless e Arquitetura Orientada a Eventos

Serverless significa não gerenciar servidores: o provedor cuida da infraestrutura e escala, e o cliente paga pelo uso.

- **Funções como serviço (FaaS)**

AWS Lambda, Azure Functions e Google Cloud Functions. Código curto executado em resposta a eventos (requisição HTTP, arquivo gravado, mensagem, agendamento). Escala automaticamente, inclusive a zero, e cobra por invocação e por tempo e memória usados.

- **Características e limites**

Sem estado entre invocações, tempo máximo de execução limitado (na AWS Lambda, 15 minutos), memória e disco limitados, e partida a frio (cold start), o atraso na primeira execução após inatividade. Limites de concorrência protegem o serviço.

- **Arquitetura orientada a eventos**

Produtores emitem eventos e consumidores reagem, sem se conhecerem. Serviços: filas e tópicos (AWS SQS e SNS; Azure Service Bus e Queue Storage; Google Pub/Sub), roteadores de eventos (AWS EventBridge, Azure Event Grid) e ingestão em fluxo (AWS Kinesis, Azure Event Hubs, Google Pub/Sub).

- **Orquestração e APIs**

Fluxos de trabalho sem servidor (AWS Step Functions, Azure Logic Apps e Durable Functions, Google Workflows) e gateways de API (API Gateway, Azure API Management, Google API Gateway) completam soluções sem servidores.

- **Quando usar e cuidados**

Bom para cargas intermitentes, integração e automação. Cuidados: partida a frio, limites, custo em alto volume constante, depuração distribuída e dependência do provedor (lock-in). Projete para idempotência, pois eventos podem ser entregues mais de uma vez.

SERVERLESS TEM SERVIDOR, MAS NÃO É PROBLEMA DO CLIENTE

O nome refere-se à ausência de gestão de servidores. A escalabilidade e a cobrança por uso são as vantagens; o tempo máximo de execução e a partida a frio são os limites.

7. Armazenamento e Bancos de Dados na Nuvem

Os tipos de armazenamento seguem a apostila de Infraestrutura (bloco, arquivo e objeto). Aqui estão os serviços e conceitos de nuvem.

- **Objeto, bloco e arquivo**

Objeto: Amazon S3, Azure Blob Storage e Google Cloud Storage. Bloco (discos de VMs): Amazon EBS, Azure Managed Disks e Google Persistent Disk. Arquivo: Amazon EFS, Azure Files e Google Filestore.

- **Classes e camadas de objeto**

Camadas trocam custo de armazenamento por custo e prazo de acesso. AWS: S3 Standard, acesso infrequente e classes do Glacier. Azure: quente (hot), fria (cool), cold e arquivo (archive). Google: Standard, Nearline, Coldline e Archive. Regras de ciclo de vida movem dados entre camadas automaticamente. Dados de arquivo têm tempo mínimo de retenção e prazo maior de recuperação.

- **Durabilidade e redundância**

S3 projeta durabilidade de 99,999999999% (onze noves) dos objetos. Azure Storage: LRS (três cópias em um centro de dados), ZRS (em zonas da região), GRS (LRS mais cópia assíncrona em outra região) e GZRS (ZRS mais outra região). Google: regional, dual-region e multirregional.

- **Bancos gerenciados**

Relacionais: Amazon RDS e Aurora, Azure SQL Database, Google Cloud SQL e Spanner (relacional distribuído globalmente). NoSQL: DynamoDB, Azure Cosmos DB, Google Firestore e Bigtable. O provedor cuida de backup, atualização e alta disponibilidade.

- **Data warehouse e data lake**

Data warehouse: Amazon Redshift, Azure Synapse Analytics (evoluindo para o Microsoft Fabric) e Google BigQuery. Data lake sobre armazenamento de objeto: S3, Azure Data Lake Storage Gen2 e Cloud Storage, com catálogo e consultas (AWS Glue e Athena, Lake Formation; Synapse; BigQuery). Processamento distribuído: Amazon EMR, Azure HDInsight e Databricks, Google Dataproc.

- **Ingestão, ETL e IA**

Streaming: Kinesis, Event Hubs e Pub/Sub. ETL: AWS Glue, Azure Data Factory e Google Dataflow (Apache Beam). Plataformas de aprendizado de máquina: Amazon SageMaker, Azure Machine Learning e Google Vertex AI, integradas ao data lake.

OBJETO ESCALA E CUSTA MENOS, BLOCO TEM BAIXA LATÊNCIA

Objeto: grande escala, acesso por API, ideal para dados não estruturados e backups. Bloco: baixa latência para SO e bancos. Arquivo: compartilhamento por NFS ou SMB.

8. Identidade e Acesso: IAM, RBAC e MFA

Na nuvem, a identidade é o novo perímetro. Toda ação é autenticada e autorizada por meio do serviço de gestão de identidades e acessos (IAM).

- **AWS IAM**

Usuários, grupos, funções (roles) e políticas em JSON. Funções são assumidas com credenciais temporárias (AWS STS), preferíveis a chaves de longa duração. Avaliação: negação explícita prevalece sobre permissão explícita, e o que não foi permitido é negado por padrão. Políticas de controle de serviço (SCPs) do AWS Organizations definem o máximo permitido em contas, mas não concedem permissões. A conta raiz deve ter MFA e uso mínimo.

- **Azure: Microsoft Entra ID e Azure RBAC**

O Microsoft Entra ID (antigo Azure Active Directory) é o serviço de identidade. O Azure RBAC atribui um papel (role) a uma identidade em um escopo (grupo de gerenciamento, assinatura, grupo de recursos ou recurso); as permissões são herdadas para baixo. Recursos relacionados: Acesso Condicional, identidades gerenciadas (para serviços sem senhas) e Privileged Identity Management (acesso privilegiado sob demanda).

- **Google Cloud IAM**

Hierarquia de recursos: organização, pastas, projetos e recursos; as políticas são herdadas para baixo. Papéis básicos (Owner, Editor, Viewer) são amplos e não recomendados; preferir papéis predefinidos ou personalizados. Contas de serviço identificam aplicações.

- **Princípios**

Privilegio mínimo, separação de funções, uso de grupos e papéis em vez de permissões individuais, credenciais temporárias, revisão periódica de acessos e registro de todas as ações.

- **MFA e federação**

Autenticação multifator exige mais de um fator. A federação permite login único com o provedor de identidade da organização, por SAML 2.0 ou OpenID Connect. Segredos ficam em cofres (AWS Secrets Manager, Azure Key Vault, Google Secret Manager), e não em código.

- **RBAC e ABAC**

RBAC concede permissões por papéis. ABAC decide por atributos (etiquetas, departamento, ambiente), permitindo regras mais dinâmicas. As três nuvens suportam condições baseadas em atributos.

NEGAÇÃO EXPLÍCITA SEMPRE VENCE

Na AWS, uma política de negação explícita prevalece sobre qualquer permissão. Sem permissão, o acesso é negado (negação implícita). Papéis com credenciais temporárias reduzem o risco de vazamento de chaves.

9. Criptografia e KMS: Em Repouso, em Trânsito e Gestão de Chaves

A proteção de dados na nuvem combina criptografia em repouso e em trânsito com uma gestão cuidadosa das chaves.

- **Em repouso e em trânsito**

Em repouso: dados cifrados no armazenamento (discos, objetos, bancos), normalmente com AES-256. Em trânsito: TLS (versões atuais) entre clientes, serviços e regiões. As três nuvens cifram por padrão a maioria dos serviços de armazenamento; a diferença está em quem controla as chaves.

- **Serviços de gerenciamento de chaves**

AWS KMS, Azure Key Vault e Google Cloud KMS. Criam, guardam, rotacionam e controlam o uso de chaves, com registro de auditoria de cada uso. HSM (módulo de segurança em hardware) oferece proteção física reforçada: AWS CloudHSM, Azure Key Vault Premium e Managed HSM, Cloud HSM.

- **Criptografia de envelope**

Uma chave de dados (DEK) cifra os dados; a chave de dados é cifrada por uma chave de nível superior (KEK), guardada no KMS. Assim, os dados grandes são cifrados localmente e só a pequena chave de dados vai ao KMS.

- **Quem controla a chave**

Chaves gerenciadas pelo provedor (mais simples); chaves gerenciadas pelo cliente no KMS da nuvem (controle de política, rotação e revogação); traga sua própria chave (BYOK); e chaves mantidas fora da nuvem (por exemplo, gerenciador externo de chaves), para maior controle e requisitos regulatórios.

- **Rotação, separação e revogação**

Rotação periódica limita o impacto de comprometimento. Separar quem administra as chaves de quem administra os dados reduz riscos. Desabilitar ou excluir uma chave torna os dados protegidos por ela irrecuperáveis: planeje a exclusão com cuidado.

- **Certificados e TLS**

Certificados X.509 gerenciados (AWS Certificate Manager, Azure Key Vault, Google Certificate Manager) automatizam emissão e renovação. Terminação de TLS no balanceador ou de ponta a ponta até a aplicação, conforme a exigência de segurança.

QUEM CONTROLA A CHAVE CONTROLA O ACESSO

Cifrar não basta: a política de acesso ao KMS e o registro de uso das chaves são parte central da proteção. Sem acesso à chave, o dado cifrado não pode ser lido.

10. Segurança em Nuvem: Monitoramento, Zero Trust e Conformidade

A segurança na nuvem exige visibilidade contínua, configuração correta e conformidade com normas.

- **Registro e monitoramento**

Trilhas de auditoria das ações administrativas: AWS CloudTrail, Azure Activity Log e Google Cloud Audit Logs. Métricas e logs: Amazon CloudWatch, Azure Monitor e Google Cloud Monitoring e Logging. Centralizar e proteger os logs contra alteração é essencial para investigação.

- **Deteção e postura**

AWS: GuardDuty (deteção de ameaças), Security Hub (agregação de achados), Config (conformidade de configuração), Inspector (vulnerabilidades) e Macie (dados sensíveis no S3). Azure: Microsoft Defender for Cloud e Microsoft Sentinel (SIEM). Google: Security Command Center. Ferramentas de postura (CSPM) apontam configurações incorretas.

- **Principais riscos**

Configuração incorreta (como armazenamento público e portas abertas ao mundo), credenciais vazadas, permissões excessivas, falta de registro e dependências vulneráveis. A maioria dos incidentes em nuvem decorre de configuração e identidade, não de falha do provedor.

- **Zero Trust em nuvem**

Nenhuma confiança implícita: identidade forte e MFA, acesso com privilégio mínimo e sob demanda, verificação contínua, microssegmentação, acesso a serviços por endpoints privados e criptografia de ponta a ponta. A rede não é mais o perímetro principal (veja a apostila de Segurança).

- **Normas e conformidade**

ISO/IEC 27001 (sistema de gestão), ISO/IEC 27017 (controles para serviços em nuvem) e 27018 (proteção de dados pessoais em nuvem pública), NIST SP 800-53 (catálogo de controles), CSA Cloud Controls Matrix, relatórios SOC 2 e a LGPD. Os provedores publicam certificações; o cliente responde pela conformidade da sua parte.

- **DevSecOps na nuvem**

Análise de infraestrutura como código antes da implantação, varredura de imagens e dependências, segredos fora do código e políticas como código para impedir configurações inseguras.

MAIOR RISCO EM NUVEM: CONFIGURAÇÃO, NÃO INVASÃO DO PROVEDOR

Incidentes típicos vêm de armazenamento público, credenciais expostas e permissões amplas. Por isso, governança de identidades e monitoramento de configuração são prioridades.

11. Infraestrutura como Código, GitOps e Governança de Contas

Automatizar a criação de recursos e impor regras em toda a organização dá consistência, rastreabilidade e segurança.

- **Infraestrutura como código (IaC)**

Descreve a infraestrutura em arquivos versionados. Nativas: AWS CloudFormation e Azure Resource Manager (modelos ARM e Bicep). Multinuvem: Terraform, que usa a linguagem HCL, provedores e módulos; o OpenTofu é um projeto derivado do Terraform. Ciclo do Terraform: init, plan (mostra o que vai mudar) e apply.

- **Estado e desvio**

O Terraform mantém um arquivo de estado com o mapeamento dos recursos. Deve ficar em armazenamento remoto, com bloqueio e controle de acesso, pois pode conter dados sensíveis. Desvio de configuração (drift) é a diferença entre o real e o código; detecta-se e corrige-se com plan e apply.

- **Infraestrutura imutável e GitOps**

Em vez de alterar servidores, substituem-se por novos criados de imagens atualizadas. GitOps usa o Git como fonte da verdade do estado desejado, com ferramentas como Argo CD e Flux que sincronizam o cluster com o repositório.

- **Contas, organizações e landing zone**

Organização com várias contas, assinaturas ou projetos isola ambientes e cargas. Landing zone é um ambiente-base multiconta com segurança, rede e governança pré-configuradas (AWS Control Tower, Azure Landing Zones, Google Cloud landing zone).

- **Políticas de governança**

AWS Organizations com SCPs, Azure Policy e Google Organization Policy impõem regras (regiões permitidas, tipos de recurso, etiquetas obrigatórias, criptografia obrigatória) em todas as contas.

- **Tagueamento, cotas e limites**

Etiquetas (tags) identificam dono, ambiente, centro de custo e projeto, sustentando alocação de custos, automação e segurança. Cotas e limites de serviço protegem contra consumo excessivo e exigem planejamento de capacidade e pedidos de aumento.

PLAN ANTES DE APPLY

O plan mostra o que o Terraform alterará antes de qualquer mudança. Use-o em revisão de código e nunca aplique sem revisar o plano.

12. Custos e FinOps na Prática

A nuvem transforma custo fixo em variável. Sem governança, os gastos crescem sem controle. A definição e os princípios do FinOps estão na apostila de Governança de TI.

- **Fontes de custo**

Computação, armazenamento, rede (especialmente a saída de dados da nuvem, cobrada, enquanto a entrada costuma ser gratuita), bancos gerenciados, licenças e serviços de suporte. Transferência entre regiões e para a Internet pode surpreender.

- **Ferramentas de visibilidade**

AWS Cost Explorer e Budgets, Azure Cost Management e Billing, e Google Cloud Billing com orçamentos e alertas. Etiquetas permitem detalhar custos por área, sistema e ambiente.

- **Otimização**

Dimensionar corretamente (rightsizing), desligar recursos ociosos e ambientes fora do horário, usar reservas e planos de economia para cargas estáveis, instâncias interrompíveis para cargas tolerantes, camadas de armazenamento e regras de ciclo de vida, e arquiteturas sem servidor para cargas intermitentes.

- **Alocação e responsabilização**

Showback mostra às áreas quanto consomem; chargeback repassa o custo a elas. Métricas de custo unitário (por transação, por usuário) relacionam gasto e valor de negócio.

- **Cultura e governança**

Alinhar engenharia, finanças e negócio, com orçamentos, alertas de anomalia e revisões periódicas. Um centro de excelência em nuvem (CCoE) define padrões e boas práticas.

SAÍDA DE DADOS COSTUMA SER COBRADA, ENTRADA NÃO

Ao desenhar arquiteturas e migrações, considere o custo de transferir dados para fora da nuvem ou entre regiões, que costuma ser significativo.

13. Alta Disponibilidade, Recuperação de Desastres e Migração

Projetar para falhas e migrar de forma planejada são competências centrais.

- **Alta disponibilidade**

Distribuir a carga em várias zonas de disponibilidade com balanceador e verificações de saúde; serviços gerenciados replicados; dados com replicação entre zonas. Evitar pontos únicos de falha. As disponibilidades de componentes em série se multiplicam (veja a apostila de Infraestrutura).

- **Estratégias de recuperação de desastres (AWS)**

Da menos cara e mais lenta à mais cara e mais rápida: backup e restauração; pilot light (núcleo mínimo sempre ligado); warm standby (versão reduzida em execução); e multissítio ativo/ativo. Escolha conforme RPO e RTO exigidos.

- **Multirregião**

Protege contra falha regional, mas aumenta custo e complexidade (replicação de dados, DNS de failover, consistência). Nem toda carga precisa dessa proteção.

- **Migração: avaliação e ferramentas**

Inventariar, avaliar dependências, escolher a estratégia por aplicação e planejar a virada (cutover). Ferramentas: AWS Database Migration Service e Application Migration Service, Azure Migrate e Google Migrate to Virtual Machines. Para grandes volumes há dispositivos de transferência física (como a família AWS Snow, o Azure Data Box e o Google Transfer Appliance; confira a disponibilidade atual de cada um).

- **Migração de bancos de dados**

Homogênea (mesmo motor) ou heterogênea (motor diferente, com conversão de esquema). A replicação contínua reduz o tempo de parada na virada.

- **Testes**

Testar a recuperação de desastres regularmente. Engenharia do caos injeta falhas de propósito para validar a resiliência.

BACKUP E RESTAURAÇÃO É A ESTRATÉGIA MAIS BARATA E MAIS LENTA

Nas estratégias de DR, quanto menor o RTO e o RPO, maior o custo. Escolha a menos custosa que ainda atenda aos objetivos de recuperação.

14. Mapa de Equivalência de Serviços: AWS, Azure e Google Cloud

Referência rápida dos nomes de serviços equivalentes. Nomes e portfólios mudam com frequência; confirme na documentação atual.

- **Computação e contêineres**
VM: EC2 / Virtual Machines / Compute Engine. Kubernetes: EKS / AKS / GKE. Contêiner sem servidor: Fargate / Container Apps / Cloud Run. Funções: Lambda / Functions / Cloud Functions.
- **Armazenamento**
Objeto: S3 / Blob Storage / Cloud Storage. Bloco: EBS / Managed Disks / Persistent Disk. Arquivo: EFS / Files / Filestore. Arquivamento: S3 Glacier / camada archive / Archive.
- **Bancos de dados**
Relacional gerenciado: RDS e Aurora / Azure SQL Database / Cloud SQL e Spanner. NoSQL: DynamoDB / Cosmos DB / Firestore e Bigtable. Data warehouse: Redshift / Synapse (Fabric) / BigQuery.
- **Redes**
Rede virtual: VPC / VNet / VPC. Balanceador: ELB / Load Balancer e Application Gateway / Cloud Load Balancing. DNS: Route 53 / Azure DNS / Cloud DNS. CDN: CloudFront / Front Door e CDN / Cloud CDN. Link dedicado: Direct Connect / ExpressRoute / Interconnect. Endpoint privado: PrivateLink / Private Link / Private Service Connect.
- **Mensageria, eventos e dados em fluxo**
Fila e tópico: SQS e SNS / Service Bus / Pub/Sub. Eventos: EventBridge / Event Grid / Eventarc. Fluxo: Kinesis / Event Hubs / Pub/Sub. ETL: Glue / Data Factory / Dataflow. Processamento distribuído: EMR / HDInsight e Databricks / Dataproc.
- **Identidade, chaves e segredos**
Identidade: IAM / Entra ID e Azure RBAC / Cloud IAM. Chaves: KMS / Key Vault / Cloud KMS. Segredos: Secrets Manager / Key Vault / Secret Manager.
- **Observabilidade e auditoria**
Métricas e logs: CloudWatch / Azure Monitor / Cloud Monitoring e Logging. Auditoria: CloudTrail / Activity Log / Cloud Audit Logs. Ameaças e postura: GuardDuty e Security Hub / Defender for Cloud e Sentinel / Security Command Center.
- **Automação e IA**
IaC nativa: CloudFormation / ARM e Bicep. Multinuvem: Terraform. Aprendizado de máquina: SageMaker / Azure Machine Learning / Vertex AI.

CONCEITO VALE MAIS QUE O NOME

As provas cobram conceitos (IaaS, autoescalamento, serverless, responsabilidade compartilhada). Os nomes de serviços ajudam a reconhecer o equivalente em cada provedor.

15. Aprofundamento: FinOps na Prática e Segurança em Nuvem

Duas competências práticas de um Auditor Fiscal que fiscaliza contratos e o próprio uso de nuvem do órgão: a disciplina de FinOps para controlar o gasto na nuvem, e os controles de segurança específicos de identidade e chaves.

- **Rightsizing e Instâncias Reservadas**

Rightsizing: ajustar o tamanho (CPU, memória) dos recursos contratados ao uso real medido, evitando pagar por capacidade ociosa superdimensionada 'por precaução'. Instâncias Reservadas / Savings Plans: comprometimento de uso por um período (1 ou 3 anos) em troca de desconto significativo sobre o preço sob demanda, adequado para cargas de trabalho previsíveis e constantes (ao contrário de cargas esporádicas, mais baratas sob demanda ou com instâncias spot).

- **Instâncias Spot e Cargas Tolerantes a Interrupção**

Capacidade ociosa do provedor vendida com desconto expressivo, mas sujeita a ser retomada pelo provedor com pouco aviso prévio; adequada a processamento em lote, testes e cargas que tolerem interrupção e reinício, nunca a sistemas de produção críticos de disponibilidade contínua.

- **Governança de Custos (Tagging e Orçamentos)**

Etiquetagem (tags) de recursos por projeto, centro de custo ou secretaria permite atribuir o gasto de nuvem a quem de fato o gerou, viabilizando o rateio orçamentário e a responsabilização. Orçamentos e alertas de gasto (budgets) notificam automaticamente quando o consumo se aproxima ou ultrapassa um limite definido, antes que a fatura mensal já esteja fechada.

- **Políticas de IAM e o Princípio do Privilégio Mínimo**

Uma política de IAM (Identity and Access Management) define, de forma explícita, quais ações um usuário ou serviço pode executar sobre quais recursos. O princípio do privilégio mínimo recomenda conceder apenas as permissões estritamente necessárias à função exercida, e nunca usar credenciais de administrador amplo para tarefas rotineiras, reduzindo o impacto de uma eventual credencial comprometida.

- **Criptografia de Envelope e Gestão de Chaves (KMS)**

Em vez de criptografar diretamente um grande volume de dados com uma única chave mestra, o serviço de KMS gera uma chave de dados exclusiva para cada objeto ou operação, criptografa essa chave de dados com a chave mestra (o 'envelope') e armazena as duas juntas; isso permite rotacionar a chave mestra sem precisar recriptografar todos os dados já armazenados.

ALERTA DE PROVA - SPOT NUNCA É PARA PRODUÇÃO CRÍTICA

Instâncias Spot podem ser retomadas pelo provedor a qualquer momento com pouco aviso. Jamais utilize esse modelo para bancos de dados de produção ou sistemas fiscais que exigem disponibilidade contínua!

16. Referências e Conferência

Conferência realizada em 21/09/2026, com aprofundamento em 22/09/2026 (seção 15). Apostila criada a partir do programa SEFAZ-CE 2026 (FCC), área B02.

- **Referências**

NIST SP 800-145; documentação oficial da AWS (incluindo o AWS Well-Architected Framework e os whitepapers de recuperação de desastres), da Microsoft Azure (incluindo o Azure Well-Architected Framework) e do Google Cloud; FinOps Foundation; ISO/IEC 27001, 27017 e 27018; NIST SP 800-53; Cloud Security Alliance (Cloud Controls Matrix); Lei nº 13.709/2018 (arts. 33 a 36); Edital SEFAZ-CE 2026 (FCC), Anexo VI.

- **A conferir**

Nomes de serviços, limites (por exemplo, tempo máximo do Lambda, cotas) e preços mudam com frequência. Regulamentação vigente da ANPD sobre transferência internacional. Nome e evolução de serviços como Azure Synapse e Microsoft Fabric. Normas e diretrizes específicas do órgão sobre uso de nuvem.

- **Limites desta apostila**

Não substitui a documentação dos provedores nem a prática em laboratório. Conceitos gerais (IaaS, PaaS, serverless, IAM, KMS) valem para qualquer provedor.

REGRA DE CONTEÚDO

Este material não afirma nada sem fonte. Se houver divergência com a documentação oficial atual, ela prevalece.

GLOSSÁRIO DE SIGLAS E ABREVIATURAS

Consulte abaixo o significado e a expansão explicativa de todas as siglas contábeis, tributárias e de TI presentes nas apostilas de preparação:

ACID	Atomicidade, Consistência, Isolamento e Durabilidade. Propriedades fundamentais para transações em SGBDs.
BI	Business Intelligence. Inteligência de Negócios para mineração e análise estratégica de dados.
CAP	Consistência, Disponibilidade e Tolerância a Partições. Teorema limitador para sistemas distribuídos.
CEBRASPE	Centro de Seleção e de Promoção de Eventos. Banca examinadora oficial de concursos públicos.
CFC	Conselho Federal de Contabilidade. Órgão responsável pela edição das NBCs no território nacional.
CIAP	Controle de Crédito de ICMS do Ativo Permanente. Controle fiscal de apropriação de créditos de bens imobilizados.
CID	Confidencialidade, Integridade e Disponibilidade. Pilares de sustentação da Segurança da Informação.
COBIT	Control Objectives for Information and Related Technologies. Framework global de Governança de TI.
CPC	Comitê de Pronunciamentos Contábeis. Emissor de normas convergentes com padrões internacionais.
FGV	Fundação Getulio Vargas. Banca examinadora de certames e instituição de pesquisa econômica.
ICMS	Imposto sobre Operações Relativas à Circulação de Mercadorias e Prestações de Serviços de Transporte.
IPVA	Imposto sobre a Propriedade de Veículos Automotores. Tributo de competência estadual.
ITD	Imposto sobre Transmissão Causa Mortis e Doação. Tributo sobre heranças e doações na Bahia.
ITIL	Information Technology Infrastructure Library. Boas práticas de Gerenciamento de Serviços de TI.
KDD	Knowledge Discovery in Databases. Processo sistemático de descoberta de conhecimento em bases de dados.
LDO	Lei de Diretrizes Orçamentárias. Define as metas e prioridades para o orçamento do exercício seguinte.
LOA	Lei Orçamentária Anual. Estima as receitas e fixa as despesas públicas para o exercício financeiro.
NBC TA	Normas Brasileiras de Contabilidade Técnicas de Auditoria Independente. Alinhadas ao padrão internacional.
NBC TI	Normas Brasileiras de Contabilidade Técnicas de Auditoria Interna. Foco nos processos organizacionais.
NoSQL	Not Only SQL. Família de SGBDs não relacionais estruturados para alto desempenho e escalabilidade.
OLAP	Online Analytical Processing. Ferramentas analíticas baseadas em cubos de dados multidimensionais.
PAF-BA	Processo Administrativo Fiscal do Estado da Bahia. Lei nº 3.956/1981 que regula o contencioso.
PPA	Plano Plurianual. Planejamento estratégico governamental de médio prazo (4 anos).
RICMS-BA	Regulamento do ICMS do Estado da Bahia. Decreto regulamentador do principal imposto estadual.
RUP	Rational Unified Process. Processo de desenvolvimento de software disciplinado e preditivo.
SEFAZ-BA	Secretaria da Fazenda do Estado da Bahia. Órgão de arrecadação e controle fiscal baiano.

SGBD	Sistema de Gerenciamento de Banco de Dados. Software de controle e armazenamento seguro de dados.
SQL	Structured Query Language. Linguagem declarativa padrão para consulta em SGBDs relacionais.
TI	Tecnologia da Informação. Recursos de hardware, software e infraestrutura de rede corporativa.
XP	Extreme Programming. Metodologia ágil de engenharia de software focada em excelência técnica.